

Módulo	ANÁLISIS FORENSE
Nombre y	Pedro Oller Serrano
← Fecha	15/05/2025

Para la resolución del ejercicio se deberá responder a las siguientes preguntas **sobre esta plantilla**. Será necesario atender a los siguientes puntos:

- Contestar a las preguntas en el orden establecido.
- Limitarse a contestar a las preguntas planteadas mediante una respuesta directa que posteriormente se deberá argumentar y desarrollar con detalle así como utilizar, cuando proceda, las evidencias facilitadas para el análisis
- El ejercicio se puede resolver bien analizando los resultados de la ejecución de la herramienta WLR que se incluyen en el fichero comprimido, bien analizando el disco facilitado del equipo víctima (mediante una herramienta forense, tipo Autopsy, Caine o similar). Ambas opciones son válidas. Para la opción de análisis con herramienta forense no es necesario saber la cuenta de administrador del equipo víctima.
- Como orientación, el ejercicio debe tener una extensión comprendida entre 10 y 15 páginas.

Pregunta 1 (2 puntos):

¿Cómo, cuándo y desde dónde accedió el intruso al servidor? Indique el detalle de las evidencias (archivo, evento, etc.) de las que se deduce esta información.

Se producen dos conexiones:

1.- El día 07/05/2021 a las 11:46:59 con logon id, 0x2111C, mediante conexión remota a través de VRDP de virtualbox, lo que explica el 'Logon type: 2' y que no aparezca un puerto abierto para esa conexión en cport.html y además explica que aparezca la 'Source Network Address' como 127.0.0.1. El atacante conocía: el puerto de conexión, la ip privada del servidor y las credenciales de administrador del servidor.

Evidencia: Security.evtx y LastActivityView.html

2.- El día 07/05/2021 a las 13:42:23 mediante RDP en la máquina virtual del servidor. Inicio de sesión exitoso con Logon Type 10 y event id 4624 , a través de la ip privada 172.16.0.3 lo que sustenta que fue el trabajador descontento. Elevación de privilegios con event id 4672 como administrador desde una posible VPN con ip 129.205.96.3 de origen Lagos, Nigeria desde el equipo DESKTOP-SLLQEAM. **Evidencias:**

Security.evtx y nbstat.txt

Evidencia del primer inicio de sesión:

```
Process Name: C:\Windows\system32\svchost.exe
Information 07/05/2021 11:46:59 Microsoft-Windows-Security-Auditing 4672 Special Logon "Special privileges assigned to new logon.
Subject:
Security ID: S-1-5-21-1846813697-208363348-2122892913-500
Account Name: Administrador
Account Domain: WIN-SF01JTM2DHI
Logon ID: 0x2111C
Privileges:
SeSecurityPrivilege
SeTakeOwnershipPrivilege
SeLoadDriverPrivilege
SeBackupPrivilege
SeRestorePrivilege
SeDebugPrivilege
SeSystemEnvironmentPrivilege
SeImpersonatePrivilege
SeDelegateSessionUserImpersonatePrivilege"
```

Evidencia del segundo inicio de sesión:

```
Information 07/05/2021 13:42:28 Microsoft-Windows-Security-Auditing 4624 Logon "An account was successfully logged on."
Subject:
Security ID: SYSTEM
Account Name: WIN-SF01JTM2DHI$
Account Domain: WORKGROUP
Logon ID: 0x3E7
Logon Information:
Logon Type: 10
Restricted Admin Mode: No
Virtual Account: No
Elevated Token: Yes
Impersonation Level: Impersonation
New Logon:
Security ID: S-1-5-21-1846813697-208363348-2122892913-500
Account Name: Administrador
Account Domain: WIN-SF01JTM2DHI
Logon ID: 0x276318
Linked Logon ID: 0x0
Network Account Name: -
Network Account Domain: -
Logon GUID: {00000000-0000-0000-0000-000000000000}
Process Information:
Process ID: 0x3f0
Process Name: C:\Windows\System32\svchost.exe
Network Information:
Workstation Name: WIN-SF01JTM2DHI
Source Network Address: 129.205.96.3
Source Port: 0
```

Pregunta 2 (3 puntos):

¿Qué acciones fueron realizadas por el intruso a partir de su acceso? Indique el detalle de las evidencias (archivo, evento, etc.) de las que se deduce esta información.

Respuesta:

A las 11:46:59 accede al servidor mediante VRDP con logon id 0x2111C. Gracias al primer inicio de sesión, a las 12:14:44 el atacante procede a la instalación de Chrome y desde las 12:15:30 hasta 12:19:43 lo emplea para navegar por internet donde se puede observar como descarga netscan, 7zip, process hacker, Mimikatz bajo el pseudónimo de '2.2.0 20200918 Zerologon encrypted.zip' y además hace búsquedas de currículums falsos y termina por descargar uno de ellos. Instala netscan a las 12:16:39, luego instala 7-zip a las 12:16:53, a las 12:19:45 accede al zip de zerologon y posteriormente renombra la carpeta de '\curriculum' 12:36:22 y accede a esa misma carpeta, donde abre el cv falso descargado 12:36:25.

Desde las 12:37:32 hasta las 12:37:36 realiza 6 copias del currículum falso y luego desde las 12:37:46 hasta 12:38:19 procede a renombrar cada uno de los documentos. A las 12:51:52 se observa una modificación manual de las políticas de contraseñas del dominio local por parte del administrador, ID del evento, 4739 "Authentication Policy Change", posiblemente para permitir el acceso desde la ip nigeriana. A las 12:55:39 el atacante intenta cambiar la contraseña de la cuenta de administrador con ID del evento, 4723 "An attempt was made to change an account's password".

Desde las 13:41:54 hasta las 13:42:23 el atacante prueba a iniciar sesión sin éxito, hasta las 13:42:23 donde consigue acceso desde la ip 129.205.96.3:49846 procedente de Nigeria, a través de la ip privada 172.16.0.3, con el sufijo de nombre de netbios '<20>', es decir, se conecta como un servidor de archivos/impresora, por lo que posiblemente empleé esa dirección para exfiltrar o descargar archivos desde el servidor.

Tras este inicio de sesión, el atacante ejecuta netscan.exe a las 13:44:01 hasta alrededor de las 13:52:00, con el posible objetivo de descubrir otros equipos, identificar puertos abiertos y establecer posibles vectores laterales para avanzar a través de la red de la compañía. Alrededor de 6 minutos más tarde a las 13:50:29 se ejecuta la herramienta ProcessHacker2 con el objetivo de inspeccionar y posiblemente manipular procesos activos como antivirus, EDR... con el objetivo de modificarlos o detenerlos.

El atacante a las 13:52:42 accede al directorio de Mimikatz (que descargó bajo el pseudónimo de zerologon) y ejecuta mimikatz, utilizado para extraer credenciales desde la memoria y el archivo SAM. Hay evidencias de acceso a archivos críticos del sistema (SAM, SECURITY, SYSTEM), lo que confirma un intento o éxito en extraer hashes de contraseñas locales. La actividad de mimikatz se mantiene hasta las 14:01:37.

Posteriormente, a las 14:12:47 el atacante ejecuta la interfaz gráfica de 7-zip, 7zFM.exe aunque aparentemente no fue el momento en el que compilo los currículums. A las 14:54:29 se observa un acceso a unidad de red (z:\) del escritorio remoto DESKTOP-SLLQEAM con ip 129.205.96.3 sobre 172.16.0.3, desde esta unidad de red se produce la descarga-copia hacia el escritorio de Mimikatz_trunk.zip, posiblemente descargó este nuevo mimikatz ya que el anterior pudiera ser que no consiguiera los hashes. Con el archivo Mimikatz_trunk.zip en el escritorio el atacante lo descomprime a las 14:54:36 para posteriormente ejecutarlo hasta aproximadamente las 14:59:00.

Luego de la ejecución de Mimikatz, el atacante procede a compilar los currículums a las 14:59:16 bajo el

nombre de 'asdfghj12345677z.7z'. Tras compilar los archivos procede a eliminarlos a las 14:59:47 y unos segundos más tarde, a las 15:00:05 el atacante realiza el eliminado definitivo de los currículums desde la papelera. Pasados 17 segundos a las 15:00:22 se produce la desconexión de la ip Nigeriana por el puerto 129.205.96.3:49846, mediante el protocolo TCP con event id 103 y cierre de la sesión id 2. Según el event id y la razón de desconexión, 13 , este cierre de sesión se debe a que la sesión RDP fue desconectada por el atacante.

A las 15:01:06 desbloqueo de sesión existente WORKGROUP\Administrador, se registra un evento id 4648 con Logon Type = 2 y logon id = 0x3B5BEC luego es distinto del primer inicio de sesión, asignando un token elevado a Administrador (evento 4672). El event id 4648, Posible reconexión a través de VRDP. A las 15:01:08 se produce el cierre de la sesión con logon id = 0x3B5BEC. Debido al corto periodo de tiempo y la forma de inicio de sesión podría deberse a un proceso automatizado (o un script malicioso) el cual invocó un LogonType 2 "para consola" con la cuenta Administrador (vía svchost) únicamente para refrescar la caché de LockScreen. Por lo que hasta donde tengo de la información proporcionado por Security.evtx y el NTFS Log Tracker, la sesión del atacante con Logon id 0x2111C no se desconecto, inclusive aún cuando se hizo el volcado del servidor para las 15:14, el atacante seguía en el servidor.

Evidencia del historial de chrome:

id	url	title	visit_count	typed_count
1	https://www.goog...	descargar netscan - Buscar con Google	2	
2	https://network-sc...	Network Scanner 8.0.2 para Windows - Descargar	1	
3	https://network-sc...	Descargar Network Scanner para Windows gratis Uptod...	1	
4	https://www.goog...	descargar 7zip - Buscar con Google	2	
5	https://7-zip.es/de...	Descargar 7-Zip en español Compresor multiformato gr...	1	
6	https://www.goog...	descargar process hacker - Buscar con Google	3	
7	https://processhac...	Downloads - Process Hacker	3	
8	https://processhac...	Overview - Process Hacker	1	
9	https://www.goog...	descargar mimcat2 - Buscar con Google	2	
10	https://www.goog...	descargar mimikatz - Buscar con Google	2	
11	https://sourceforg...	mimikatz download SourceForge.net	1	
12	https://sourceforg...	Download mimikatz from SourceForge.net	1	
13	https://sourceforg...	Find out more about mimikatz SourceForge.net	1	
14	https://www.goog...	fake curriculum vitae - Buscar con Google	2	
15	chrome-error://chr...	Pin by No Fake on curriculum vitae (Ortiz Miguel)	1	
16	https://www.pinte...	Pin by No Fake on curriculum vitae (Ortiz Miguel)	1	
17	https://www.goog...	ejemplo curriculum - Buscar con Google	3	
18	https://www.goog...	ejemplo curriculum - Búsqueda de Google	2	
19	https://www.goog...	ejemplo curriculum pdf - Buscar con Google	2	
20	https://www.mod...	Curriculum Vitae en PDF CV en PDF	1	
21	https://www.udlap...	Ejemplo de Curriculum Vitae	1	

Evidencia de los currículums:

1439	56458653		Writing Content of...	Data Runs(in Volu...		
1440	56464921	2021-05-07 12:37:32	File Creation	Data Runs(in Volu...	curriculum1 - copia...	\curriculum\curric...
1441	56467339	2021-05-07 12:37:33	File Creation	Data Runs(in Volu...	curriculum1 - copia...	\curriculum\curric...
1442	56469302	2021-05-07 12:37:33	File Creation	Data Runs(in Volu...	curriculum1 - copia...	\curriculum\curric...
1443	56471424	2021-05-07 12:37:35	File Creation	Data Runs(in Volu...	curriculum1 - copia...	\curriculum\curric...
1444	56473439	2021-05-07 12:37:36	File Creation	Data Runs(in Volu...	curriculum1 - copia...	\curriculum\curric...
1445	56481235	2021-05-07 12:37:46	Renaming File	curriculum1 - copia...	curriculum2.pdf	\curriculum\curric...
1446	56492929	2021-05-07 12:37:55	Renaming File	curriculum1 - copia...	curriculum3.pdf	\curriculum\curric...
1447	56499192	2021-05-07 12:38:03	Renaming File	curriculum1 - copia...	curriculum4.pdf	\curriculum\curric...
1448	56500104	2021-05-07 12:38:10	Renaming File	curriculum1 - copia...	curriculum5.pdf	\curriculum\curric...
1449	56506312	2021-05-07 12:38:19	Renaming File	curriculum1 - copia...	curriculum6.pdf	\curriculum\curric...

Evidencia de cambio de las políticas:

Information	07/05/2021 12:51:51	Microsoft Windows Security Auditing	Authentication Policy Change	Domain Policy was changed.
Change Type:	Directiva de contraseñas modified			
Subject:	Security ID: S-1-5-21-1846813697-288363348-2122892913-508			
	Account Name: Administrador			
	Account Domain: WIN-SF013TN2DH1			
	Logon ID: 0x2111C			
Domain:	Domain Name: WIN-SF013TN2DH1			
	Domain ID: S-1-5-21-1846813697-288363348-2122892913			
Changed Attributes:	Min. Password Age:			
	Max. Password Age:			
	Force Logoff:			
	Lockout Threshold:			

Evidencia de intento de cambio de contraseña:

```
Information 07/05/2021 12:55:39 Microsoft-Windows-Security-Auditing 4723 User Account Management "An attempt was made to change an account's password."

Subject:
  Security ID: S-1-5-21-1846813697-208363348-2122892913-500
  Account Name: Administrador
  Account Domain: WIN-SF013TM3DH1
  Logon ID: 0x2111c

Target Account:
  Security ID: S-1-5-21-1846813697-208363348-2122892913-500
  Account Name: Administrador
  Account Domain: WIN-SF013TM3DH1

Additional Information:
```

Evidencia de primer uso de mimikatz:

2223	74	2021-05-07 13:52:42			mimikatz.exe	\Users\Administra...
2224	75	2021-05-07 13:52:42			AutomaticDestinat...	\Users\Administra...
2225	18	2021-05-07 13:52:42			Roaming	\Users\Administra...
2226	38	2021-05-07 13:52:42	File Creation		mimikatz.lnk	\Users\Administra...
2227	93	2021-05-07 13:52:42	Writing Content of...	Data Runs(in Volu...	mimikatz.lnk	\Users\Administra...
2228	13	2021-05-07 13:52:42	File Creation		mimikatz (2).lnk	\Users\Administra...
2229	96	2021-05-07 13:52:42	Writing Content of...	Data Runs(in Volu...	mimikatz (2).lnk	\Users\Administra...
2230	48	2021-05-07 13:52:42	Directory Creation		WIA	\Windows\debug\...
2231	29	2021-05-07 13:52:42	File Creation		wiatrace.log	\Windows\debug\...
2232	20	2021-05-07 13:52:42	Writing Content of...	Writing Size : 146	wiatrace.log	\Windows\debug\...
2233	34	2021-05-07 13:52:42			12dc1a28e34b5a6	\Users\Administra...

Evidencia de descarga de Mimikatz_trunk.zip y ejecución:

2423	7967	2021-05-07 14:54:33	File Creation	Data Runs(in Volu...	mimikatz_trunk.zip	\Users\Administra...
2424	9867				mimikatz_trunk.zip	\Users\Administra...
2425	9966	2021-05-07 14:54:36	File Creation		mimikatz_trunk.lnk	\Users\Administra...
2426	0175		Writing Content of...	Writing Size : 543	mimikatz_trunk.lnk	\Users\Administra...
2427	0329				mimikatz_trunk.lnk	\Users\Administra...
2428	2465	2021-05-07 14:54:43	Directory Creation		mimikatz_trunk	\Users\Administra...
2429	2866	2021-05-07 14:54:43	File Creation		kiwi_passwords.yar	\Users\Administra...
2430	3157	2021-05-07 14:54:43	Writing Content of...	Data Runs(in Volu...	kiwi_passwords.yar	\Users\Administra...
2431	3737	2021-05-07 14:54:43	File Creation		mimicom.idl	\Users\Administra...
2432	4001	2021-05-07 14:54:43	Writing Content of...	Data Runs(in Volu...	mimicom.idl	\Users\Administra...
2433	4532	2021-05-07 14:54:43	File Creation		README.md	\Users\Administra...
2434	4802	2021-05-07 14:54:43	Writing Content of...	Data Runs(in Volu...	README.md	\Users\Administra...
2435	5325	2021-05-07 14:54:43	Directory Creation		Win32	\Users\Administra...
2436	5916	2021-05-07 14:54:43	File Creation		mimidrv.sys	\Users\Administra...
2437	6180	2021-05-07 14:54:43	Writing Content of...	Data Runs(in Volu...	mimidrv.sys	\Users\Administra...

Evidencia de creación de .zip y eliminación de currículums:

8	9294	2021-05-07 14:59:16	File Creation		asdfghj12345677z...	\curriculum\asdfg...
9	9516	2021-05-07 14:59:16	Writing Content of...	Writing Size : 8	asdfghj12345677z...	\curriculum\asdfg...
0	0204	2021-05-07 14:59:16	Renaming File	asdfghj12345677z...	asdfghj12345677z...	\curriculum\asdfg...
1	0687				asdfghj12345677z...	\curriculum\asdfg...
2	6727		Writing Content of...	Data Runs(in Volu...		
3	3002				service.0.etl	\Windows\Logs\N...
4	8924	2021-05-07 14:59:47	File Creation		\$IUB8UM1.pdf	\Recycle.Bin\S-1-...
5	9115	2021-05-07 14:59:47	Writing Content of...	Writing Size : 24	\$IUB8UM1.pdf	\Recycle.Bin\S-1-...
6	9337	2021-05-07 14:59:47	Move(Before)		curriculum1.pdf	\curriculum\curric...
7	9414	2021-05-07 14:59:47	Move(After)		\$RUB8UM1.pdf	\Recycle.Bin\S-1-...
8	0261	2021-05-07 14:59:47	File Creation		\$IMGASZN.pdf	\Recycle.Bin\S-1-...
9	0460	2021-05-07 14:59:47	Writing Content of...	Writing Size : 24	\$IMGASZN.pdf	\Recycle.Bin\S-1-...
0	0761	2021-05-07 14:59:47	Move(Before)		curriculum2.pdf	\curriculum\curric...
1	0849	2021-05-07 14:59:47	Move(After)		\$RMGASZN.pdf	\Recycle.Bin\S-1-...
2	1774	2021-05-07 14:59:47	File Creation		\$I6Y2QLI.pdf	\Recycle.Bin\S-1-...
3	2022	2021-05-07 14:59:47	Writing Content of...	Writing Size : 24	\$I6Y2QLI.pdf	\Recycle.Bin\S-1-...
4	2210	2021-05-07 14:59:47			curriculum	\curriculum
5	2323	2021-05-07 14:59:47	Move(Before)		curriculum3.pdf	\curriculum\curric...

Evidencia desconexión de ip nigeriana:

```
Level Date and Time Source Event ID Task Category
-----
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 103 RemoteFX module The disconnect reason is 13
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 72 RemoteFX module Interface method called: GetServerAutoReconnectInfo
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 72 RemoteFX module Interface method called: GetServerAutoReconnectInfo
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 72 RemoteFX module Interface method called: DisconnectNotify
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 72 RemoteFX module Interface method called: SetErrorInfo(0x0)
Information 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 72 RemoteFX module Interface method called: PreDisconnect(0)
Warning 07/05/2021 15:00:22 Microsoft-Windows-RemoteDesktopServices-RdpCoreTS 228 RemoteFX module Disconnect trace: CUMRDPConnection Disconnect trace: 'calling
```

Evidencia de conexión y desconexión de la última conexión RDP:

```
Information 07/05/2021 15:01:08 Microsoft-Windows-Security-Auditing 4634 Logoff "An account was logged off."
Subject:
Security ID: S-1-5-21-1846813697-208363348-2122892913-500
Account Name: Administrador
Account Domain: WIN-SF01JTM2DHI
Logon ID: 0x385BEC
Logon Type: 2
This event is generated when a logon session is destroyed. It may be positively correlated with a logon event using the Logon ID value the same computer.
Information 07/05/2021 15:01:08 Microsoft-Windows-Security-Auditing 4672 Special Logon "Special privileges assigned to
```

Pregunta 3 (1 puntos):

¿Cuándo termina las acciones del intruso? Indique el detalle de las evidencias (archivo, evento, etc.) de las que se deduce esta información.

Respuesta:

Se divide en dos sesiones:

1. La primera, que es la conexión mediante VRDP a las 11:46:59 con Logon id 0x2111C, no llega a establecer un cierre de sesión en las pruebas aportadas por el volcado de la imagen del servidor ya que no existe un event id 4634 bajo el Logon id 0x2111C. Lo curioso de esto, es que mientras aún se encontraba el atacante en la red del servidor, se comenzó el volcado.

Evidencia: Security.evtx

2. En segundo lugar, se encuentra la intrusión mediante la posible VPN con ip 129.205.96.3: 49846. En esta conexión si se observa un cierre de sesión a las 15:00:22 con event id 103 y cierre de su respectiva sesión con id 2. Según el event id 103 y la razón de desconexión cuyo número identificativo es 13, este cierre de sesión se debe a que la sesión RDP fue desconectada por el atacante.

Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS

%4Operational.evtx

Pregunta 4 (2 puntos):

Realice una línea de tiempos de lo ocurrido el día 7/5/2021 con la hora y el evento ocurrido.

Respuesta:

1. 07/05/2021 9:26:27 Se apaga el servidor que llevaba encendido desde el día anterior. **Evidencia: LastActivityView.html**
2. 07/05/2021 9:59:43 Logon del propio sistema bajo la cuenta de Administrador (evento 4624, LogonType 2) y se elevan privilegios bajo el evento 4648 y el Logon ID = 0x3E7 para posteriormente a las 9:59:45 reiniciar el servidor. **Evidencia: LastActivityView.html y Security.evtx**
3. 07/05/2021 Entre las 10:00:24 y las 10:29:18 se realiza otro logon del propio sistema para tareas propias bajo la cuenta de administrador (evento 4624, LogonType 2) y se elevan privilegios bajo el evento 4648, se inicia el firewall (event id 5033) etc.. Para finalmente volver a apagarse y reiniciarse de inmediato a las 10:29:28. **Evidencia: LastActivityView.html y Security.evtx**
4. 07/05/2021 11:13:19 hasta las 11:46:26 En este intervalo de tiempo el servidor se reinicia un total de cuatro veces hasta que finalmente inicia sin problemas (event id, 4624, 4672, 5033...). **Evidencia: LastActivityView.html y Security.evtx**
5. 07/05/2021 11:46:59 Inicio de sesión, bajo Logon id, 0x2111C y event id 4648, y posterior 4624 que indica que ha sido un éxito, mediante conexión remota a través de VRDP de virtualbox, con el 'Logon type: 2' y la ip 127.0.0.1. **Evidencia: LastActivityView.html y Security.evtx**
6. 07/05/2021 11:47:01 Proceso Explorer.exe establece conexión HTTPS, IP del servidor: 10.0.3.15, IP remota: 20.54.37.73, puerto 443 (HTTPS). **Evidencia: cports.html**
7. 07/05/2021 11:53:32 Ejecución del sniffer Wireshark, posible uso del atacante par escanear la red aunque Wireshark ya se encontraba instalado antes de su intrusión. No se encuentra ninguna tarea programada para su ejecución a esta hora. **Evidencia: Administrador_NTUSER.DAT, amcache.txt**
8. 07/05/2021 12:09:43 Inicio de sesión exitoso desde la ip Nigeriana 129.205.96.3 y puerto 51936, mediante el protocolo TCP con event id 131 y sesión id 0. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx (no aparece en security.evtx)**
9. 07/05/2021 12:09:54 Desconexión de la ip Nigeriana por el puerto 129.205.96.3:51936, mediante el protocolo TCP con event id 103 y cierre de la sesión id 0. Según el event id y la razón de desconexión, 14, este cierre de sesión se debe a un error en la inicialización de la sesión de escritorio remoto. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx (no aparece en security.evtx)**
10. 07/05/2021 12:10:09 Inicio de sesión exitoso desde la ip Nigeriana y puerto 129.205.96.3:51937, mediante el protocolo TCP con event id 131 y sesión id 1. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx (no aparece en security.evtx)**
11. 07/05/2021 12:11:18 Desconexión de la ip Nigeriana por el puerto 129.205.96.3:51937, mediante el protocolo TCP con event id 103 y cierre de la sesión id 1. Según el event id, este cierre de sesión se debe a un error en la inicialización de la sesión de escritorio remoto.. **Evidencia: Microsoft-Windows-RemoteDeskxtpServices-RdpCoreTS%4Operational.evtx (no**

aparece en security.evtx)

12. 07/05/2021 12:12:09 svchost.exe inicia en UDP puerto 61943 en dirección local, 172.16.0.3 con SSDPSRV (Servicio de descubrimiento UpnP) activo. Puede ser activado por software como Wireshark. El atacante podría estar haciendo un reconocimiento para comprobar el error de las conexiones. **Evidencia: cports.html**
13. 07/05/2021 12:14:44 Instalación de chrome.exe. Appld: C:\Users\Administrador\Desktop\ChromeSetup.exe. **Evidencia: LastActivityView.html y Administrador_NTUSER.DAT.**
14. 07/05/2021 12:15:30 hasta 12:19:43 navega por internet mediante Chrome y se puede observar como descarga netscan, 7zip, process hacker, Mimikatz bajo el pseudónimo de '2.2.0 20200918 Zerologon encrypted.zip' y además hace búsquedas y descarga de CV's falsos. **Evidencia: History.sql de Chrome**
15. 07/05/2021 12:19:45 Acceso al archivo relacionado con Zerologon (2.2.0 20200918 Zerologon encrypted.zip) imagino que decompila el ZIP aunque no sale reflejado en \$MFT, \$LogFile y \$UsnJrnl_\$J.bin . **Evidencia: LastActivityView.html**
16. 07/05/2021 12:33:45 Chrome abrió el PDF "curriculum1.pdf" (o al menos intentó hacerlo), **Evidencia: Administrador_NTUSER.DAT**
17. 07/05/2021 Desde las 12:34:25 hasta las 12:35:54, enumeración de grupos locales por parte de Chrome.exe con privilegios de administrador, comportamiento anómalo del mismo aunque tanto el certificado de google como el hash del archivo ejecutable parecen legítimos. Con ID del evento 4798. **Evidencia: Security.evtx**
18. 07/05/2021 12:36:22 El atacante renombra la carpeta 'curriculum', el LSN es 256363674. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
19. 07/05/2021 12:36:25 Acceso a carpeta C:\curriculum y apertura de documentos PDF. Posible comprobación del contenido. **Evidencia: LastActivityView.html**
20. 07/05/2021 12:37:32 hasta 12:37:36 El atacante realiza 6 copias del currículum falso que había descargado. LSN 256464921. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
21. 07/05/2021 12:37:46 hasta 12:38:19 Renombra cada una de las copias. LSN 256481235. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
22. 07/05/2021 12:35:54 hasta 12:47:47 enumeración de grupos locales por los procesos explorer.exe y dllhost.exe con ID del evento, 4798. **Evidencia: Security.evtx**
23. 07/05/2021 12:51:51 Modificación manual de las políticas contraseñas del dominio local por parte del administrador, ID del evento, 4739 con Logon ID: 0x2111C, que es el del atacante "Authentication Policy Change". **Evidencia: Security.evtx**
24. 07/05/2021 12:55:39 Intento de cambio de contraseña de la cuenta de administrador con ID del evento, 4723 "An attempt was made to change an account's password", con Logon ID: 0x2111C.

Evidencia: Security.evtx

25. 07/05/2021 12:55:39 Inicio de sesión local con Logon type 2 y event id 4624, elevación de privilegios a administrador con event id 4672 con Logon ID: 0x206E53. Finalmente, cierre de sesión a la misma hora con event id 4634. **Evidencia: Security.evtx**
26. 07/05/2021 13:41:54 Inicio de sesión exitoso desde una ip Nigeriana y puerto 129.205.96.3:49843, mediante el protocolo TCP con event id 131 y sesión id 2. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**
27. 07/05/2021 13:42:05 Desconexión de la ip Nigeriana por el puerto 129.205.96.3:49843, mediante el protocolo TCP con event id 103 y cierre de la sesión id 2. Según el event id y la razón de desconexión, 14, este cierre de sesión se debe a un error en la inicialización de la sesión de escritorio remoto. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**
28. 07/05/2021 13:42:05 Inicio de sesión exitoso desde una ip Nigeriana y puerto 129.205.96.3:49845, mediante el protocolo TCP con event id 131 y sesión id 3. Desconexión de la ip Nigeriana por el puerto 129.205.96.3:49843, mediante el protocolo TCP con event id 103 y cierre de la sesión id 3. Según el event id y la razón de desconexión, 14, este cierre de sesión se debe a un error en la inicialización de la sesión de escritorio remoto. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**
29. 07/05/2021 13:42:20 Inicio de sesión exitoso desde una ip Nigeriana y puerto 129.205.96.3:49846, mediante el protocolo TCP con event id 131 y reconexión a la sesión id 2 event id 66. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**
30. 07/05/2021 13:42:23 Inicio de sesión exitoso con Logon Type 10 y event id 4648 de uso de credenciales y posterior 4624 validando las credenciales. Emplea RDP ya que es un Logon Type 10. Elevación de privilegios con event id 4672 como administrador desde una posible VPN con ip 129.205.96.3 de origen Lagos, Nigeria desde el equipo DESKTOP-SLLQEAM. **Evidencias: Security.evtx y nbstat.txt**
31. 07/05/2021 13:42:25 Reconexión a la sesión id 1 con event id 66 de 129.205.96.3:49846. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx (no aparece en security.evtx)**
32. 07/05/2021 13:44:00 hasta las 13:52:42 aproximadamente, ejecución de netscan.exe por parte del atacante. Con LSN 258089294 **Evidencia: Administrador_NTUSER.DAT y Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**
33. 07/05/2021 13:50:29 Ejecución de la herramienta ProcessHacker2. **Evidencia: Administrador_NTUSER.DAT**
34. 07/05/2021 13:50:56 Creación de carpeta Process Hacker 2 con LSN 258304082. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS%4Operational.evtx**

35. 07/05/2021 13:52:41 Ejecución de la aplicación mspaint.exe tras abrir el icono de mimikatz.ico.
Evidencia: Administrador_NTUSER.DAT
36. 07/05/2021 13:52:42 hasta 14:01:37 Acceso al directorio de Mimikatz y ejecución de Mimikatz (C:\Users\Administrador\Desktop\gentilkiwi-mimikatz-09fb1f6\). **Evidencia: LastActivityView.html y \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
37. 07/05/2021 14:12:47 Ejecución de la interfaz gráfica de 7-zip (7zFM.exe). **Evidencia: Administrador_NTUSER.DAT**
38. 7/05/2021 14:54:29 Acceso a unidad de red (z:\) del escritorio remoto DESKTOP-SLLQEAM con ip 129.205.96.3 sobre 172.16.0.3. Descarga en el escritorio Mimikatz_trunk.zip con LSN 260917967. **Evidencia: LastActivityView.html y \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
39. 7/05/2021 14:54:36 hasta 14:54:54 Apertura de mimikatz_trunk.zip y ejecución (C:\Users\Administrador\Desktop\mimikatz_trunk.zip con LSN 260919966. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
40. 7/05/2021 14:59:16 Creación del archivo comprimido con los currículums que había copiado, bajo el nombre 'asdfghj12345677z.7z'. Con LSN 261069294. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
41. 7/05/2021 14:59:47 Movimiento de currículums a la papelera \$Recicled.Bin. Con LSN 261089337. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
42. 7/05/2021 15:00:05 Borrado definitivo de los currículums. Con LSN 261108433. **Evidencia: \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
43. 7/05/2021 15:00:22 Desconexión de la ip Nigeriana por el puerto 129.205.96.3:49846, mediante el protocolo TCP con event id 103 y cierre de la sesión id 2. Según el event id y la razón de desconexión, 13, este cierre de sesión se debe a que la sesión RDP fue desconectada por el atacante. **Evidencia: Microsoft-Windows-RemoteDesktopServices-RdpCoreTS %4Operational.evtx (no aparece en security.evtx)**
44. 07/05/2021 15:01:06 hasta 15:01:08 Desbloqueo de sesión existente WORKGROUP\Administrador, se registra un evento id 4648 con Logon Type = 2, Logon Process = User32 y logon id = 0x3B5BEC luego es distinto del primer inicio de sesión, asignando un token elevado a Administrador (evento 4672). Debido al corto periodo de tiempo y la forma de inicio de sesión podría deberse a un proceso automatizado (o un script malicioso) el cual invocó un LogonType 2 "para consola" con la cuenta Administrador (vía svchost) únicamente para refrescar la caché de LockScreen. **Evidencia: Security.evtx y \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**
45. 07/05/2021 15:01:08 Cierre de sesión y del subprocesso gráfico DWM-3. Tres eventos **4634**: dos de DWM-3 (Desktop Window Manager) y uno de Administrador (Logon Type 2) que se relaciona

con el event id 4648, por lo que este cierre de sesión puede deberse a la finalización de la tarea programada. **Evidencia: Security.evtx**

46. 07/05/2021 A partir de las 15:14 hasta las 15:16 se hace el volcado del servidor por parte del administrador, LSN 261311983. **Evidencia: Security.evtx y \$MFT, \$LogFile y \$UsnJrnl_\$J.bin con la aplicación NTFS Log Tracker v1.8**

Desconexión humana: No hay evento de logoff (2 o 7) que cierre la sesión interactiva original con VRDP. Por tanto, el atacante permaneció activo, el trabajador entró cuando el atacante aún se encontraba dentro.

Pregunta 5 (2 puntos):

Realice un resumen forense con los siguientes apartados:

1. Antecedentes del caso.

En este apartado se deberán explicar los motivos que han llevado a la empresa a pensar que el equipo ha sido atacado.

2. Informe ejecutivo.

- a. Introducción.
- b. Descripción.
- c. Recomendaciones.

3. Informe técnico.

- a. Objetivos y alcance.
- b. Metodología del análisis.
- c. Listado de evidencias.
- d. Proceso de análisis forense.
- e. Conclusiones.
- f. Recomendaciones.

El informe no debe tener una extensión superior a 1 o 2 hojas y debe realizarse dentro de la siguiente casilla de respuesta.

Respuesta:

1. Antecedentes del caso

Un Windows Server 2016 expuesto en VirtualBox durante la pandemia para compartir ficheros fue aislado de la red interna. Recursos humanos encontró un archivo cifrado en lugar de currículums. El administrador detectó NetScan en ejecución. Se sospecha de un ex empleado de IT con acceso previo a credenciales e IP.

2. Informe Ejecutivo

a. Introducción

El 07/05/2021, el servidor Windows Server 2016 de la empresa fue víctima de accesos no autorizados y manipulación de configuraciones críticas. Se detectó un total de dos vectores de entrada:

- 1. Mediante la consola virtual de VirtualBox (VRDP)
- 2. A través de Remote Desktop Protocol (RDP) desde una IP en Nigeria

b. Descripción

El atacante empleó dos vectores de entrada, un primer acceso (07/05/2021 11:46:59) con credenciales de "Administrador" y conocimiento del puerto VRDP. Probable autor, ex empleado de IT y un segundo acceso (07/05/2021 13:42:23) mediante RDP como "Administrador" desde 129.205.96.3 (Nigeria), usando VPN. En cuanto a las acciones post intrusión, el atacante ejecuta netscan.exe para mapear la red. Se produce una

conexión HTTPS hacia 20.54.37.73:443, posiblemente sea irrelevante. Se produce una modificación de políticas de contraseñas e intento de modificar la contraseña de administrador. El atacante también descargó herramientas como Process Hacker, Mimikatz, 7-Zip y descargó currículums falsos, posiblemente para suplantar los auténticos.

c. Recomendaciones

1. **Seguridad en VirtualBox:** Deshabilitar o restringir VRDP a direcciones IP seguras (lista blanca) e implementar IAM, con el principio de mínimo privilegio. Rotación de claves periódicas.
2. **Restricción de Servicios Innecesarios**
3. **Fortalecimiento de Políticas de Contraseña y Auditoría**
4. **Monitoreo de Conexiones Entrantes/Salientes:** Desplegar IDS/IPS
5. **Control de Herramientas de Red y Forenses:** Desplegar EDR con detección de procesos sospechosos y bloqueo automático de ejecución sin aprobación previa.

3. Informe Técnico

a. Objetivos y Alcance

Objetivos: Identificar cómo, cuándo y desde dónde el atacante accedió al servidor. Reconstruir con precisión la línea de tiempo del 07/05/2021. Documentar las evidencias que prueban cada suceso (eventos, artefactos NTFS, conexiones de red, archivos de actividad). Determinar el modus operandi del intruso y realizar recomendaciones para prevenir futuras intrusiones.

Alcance: Servidor Windows Server 2016 (IP interna 172.16.0.3, IP NAT 10.0.3.15), alojado en VirtualBox.

b. Metodología del Análisis

1. **Recolección de Evidencias:** Empleo de 'Autopsy 4.22.1' para la obtención de los archivos de registro (.evtx), artefactos de usuario y metadatos del sistema de ficheros.
2. **Normalización de Tiempos:** Conversión de todas las marcas de tiempo a CEST (UTC+2).
3. **Análisis de Conexiones de Red:** Correlación con eventos de RDP para identificar intentos fallidos y éxitos de Remote Desktop.
4. **Inspección de Metadatos NTFS.**
5. **Verificación de Actividad de Aplicaciones:** Revisión de registros de Chrome (History.sql) para determinar descargas de software malicioso (Mimikatz, ZeroLogon) y archivos de currículum. Revisión del amcache mediante (AmcacheParser), Default User_NTUSER.DAT (Regripper) y artefactos NTFS (\$MFT, \$LogFile, \$UsnJrnl_\$J.bin).

c. Listado de Evidencias

- **Conexión RDP y Autenticaciones Clave:** LogonType 10 a las 07/05/2021 13:42:23 desde IP 129.205.96.3 (Evento 4624; reconexión sesión ID 2). "Special Logon" y elevación de privilegios a las 11:46:59 (Evento 4672).
- **Herramientas Maliciosas Ejecutadas:** Ejecución de **netscan.exe** (07/05/2021 11:44:00 y 13:44:00). Ejecución de **Process Hacker 2** (07/05/2021 11:50:29 y 13:50:29). Ejecución de **mimikatz** vía mspaint.exe (07/05/2021 13:52:41).
- **Descarga y Manipulación de Archivos de "Currículum":** Descarga de mimikatz_trunk.zip, 7-Zip y currículums falsos (07/05/2021 12:14-12:19). Renombrado masivo y copias de "C:\curriculum" (Alrededor de 12:36-12:37). Creación de un 7z con los currículums y borrado definitivo (14:59-15:00).
- **Intento de Cambio de Contraseña y Política:** Evento 4739 a las 12:51:51 y evento 4723 a las 12:55:39.

d. Proceso de Análisis Forense

1. **Recolección Inicial:** Se emplea la herramienta de Autopsy para el análisis de la iso del servidor

donde se obtiene los logs del sistema, los artefactos etc. Los archivos LastActivityView.html y cports.html son aportados por la empresa.

2. Reconstrucción de Sesiones

- Sesión SYSTEM al arranque (Logon ID 0x3E7).
- Sesión “Administrador” vía VRDP (Logon ID 0x2111C, 11:46:59).
- Sesión RDP de “Administrador” desde 129.205.96.3 (13:42:23).
- Sesión breve de LockScreen (Logon ID 0x3B5BEC, 15:01:06-08).

3. Detección de Vectores de Acceso

- VRDP: LogonType 2 a las 11:46:59 con source 127.0.0.1.
- RDP: LogonType 10 a las 13:42:23 desde 129.205.96.3.

4. De los artefactos de Usuario se obtiene:

- Ejecución de herramientas forenses (Wireshark, netscan.exe, Process Hacker, Mimikatz, 7zFM).
- Descargas desde Chrome (netscan, 7-Zip, Process Hacker, Mimikatz, currículums falsos).

5. Metadatos NTFS: Modificaciones en C:\curriculum (copias y renombrados 12:36-12:37).

Creación de ZIP y eliminación de currículums (14:59-15:00). Ejecución de mimikatz_trunk (14:54).

e. Conclusiones

El atacante, con acceso a credenciales y al puerto VRDP, explotó configuraciones predeterminadas débiles para ingresar por VRDP y luego por RDP. En la fase de post explotación usó Mimikatz y NetScan para reconocimiento interno y extracción de credenciales, luego procedió a copiar y renombrar currículums para luego compilar y finalmente eliminarlos, para ocultar rastros. La falta de logoff del primer logon del atacante permitió su persistencia, y el patrón de ataque sugiere un empleado de IT. Es vital reforzar controles remotos y habilitar auditorías en tiempo real.

f. Recomendaciones

VRDP: Deshabilitar o restringir; cambiar puertos; usar contraseñas únicas; limitar por IP.

Contraseñas: Vigilar eventos 4739/4723/4724; auditar cambios.

RDP: Alertas para LogonType 10 fuera de la LAN; exigir VPN; bloquear RDP directo a 172.16.0.3.

Herramientas de Análisis: Desplegar EDR que bloquee NetScan, Process Hacker, Mimikatz.

Respuesta a Incidentes: Procedimiento para aislar VM, recolectar pruebas y restaurar desde snapshot limpio.

Administrador: Cambiar todas las contraseñas privilegiadas; deshabilitar “Administrador”.

Control Interno: Revisar y revocar accesos al salir el personal de TI; auditar permisos.

IAM/MFA Avanzado: MFA basado en ubicación (bloquear Nigeria); privilegios breves y auditables.